

CÓMO REALIZAR UNA EVALUACIÓN DE RIESGOS DE CIBERSEGURIDAD

*Guía práctica para definir el alcance, identificar, analizar, tratar,
documentar y monitorear el riesgo*

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Propósito y aviso de uso responsable

Este manual enseña un método repetible y basado en evidencia para evaluar riesgos de ciberseguridad. Está dirigido a analistas de GRC, profesionales de seguridad, gerentes, auditores, estudiantes y personas que cambian de carrera. No sustituye asesoría legal, regulatoria, de auditoría, seguros o de otros profesionales. Adapte el método a la organización, industria, jurisdicción y apetito de riesgo.

La seguridad humana es lo primero. Las decisiones de riesgo deben proteger a las personas, los servicios esenciales, la privacidad, la accesibilidad y la resiliencia. Nunca se deben ocultar riesgos materiales ni presionar al evaluador para obtener una calificación predeterminada.

Cómo utilizar este manual

- Lea los capítulos 1 al 5 para comprender el método.
- Use los capítulos 6 al 12 como procedimiento de trabajo.
- Use los capítulos 13 al 16 para informes, tratamiento, monitoreo y portafolio.
- Copie las plantillas a una hoja de cálculo, plataforma GRC, sistema de tickets o repositorio aprobado.

Tabla de contenido

- 1. Fundamentos de la evaluación de riesgos
- 2. Funciones, gobierno e independencia
- 3. Definición del alcance y contexto
- 4. Identificación de activos, servicios y datos
- 5. Identificación de amenazas y eventos
- 6. Identificación de vulnerabilidades y brechas
- 7. Análisis de probabilidad
- 8. Análisis de impacto
- 9. Cálculo y comunicación del riesgo
- 10. Evaluación de controles y riesgo residual
- 11. Planes de tratamiento
- 12. Registro de riesgos
- 13. Informes para líderes
- 14. Monitoreo y reevaluación
- 15. Errores comunes y calidad
- 16. Proyecto de portafolio y plan de 30/60/90 días
- 17. Plantillas y ejemplos
- 18. Glosario y referencias oficiales

1. Fundamentos de la evaluación de riesgos

Una evaluación de riesgos de ciberseguridad es un proceso estructurado para comprender qué puede salir mal, por qué podría ocurrir, qué tan graves serían las consecuencias y qué debe hacerse. NIST SP 800-30 presenta la evaluación como parte de un proceso más amplio de administración del riesgo. NIST CSF 2.0 incorpora la estrategia, las funciones, la política, la supervisión y la cadena de suministro en GOVERN, y la identificación de riesgos en IDENTIFY.

Término	Significado práctico
Activo	Sistema, servicio, proceso, persona, instalación, conjunto de datos, proveedor o capacidad con valor.
Amenaza	Actor o circunstancia con potencial de causar daño.
Evento de amenaza	Evento específico, como robo de credenciales, ransomware, mala configuración o caída de un proveedor.
Vulnerabilidad	Debilidad que puede explotarse o contribuir al daño.
Control	Salvaguarda que modifica la probabilidad, el impacto o ambos.
Riesgo inherente	Riesgo antes de considerar los controles actuales.
Riesgo residual	Riesgo que permanece después de considerar los controles.
Apetito de riesgo	Cantidad y tipo general de riesgo que la organización está dispuesta a asumir.
Tolerancia	Variación aceptable y específica alrededor de objetivos o límites.

Redacción sencilla del riesgo

Debido a que [evento de amenaza] puede aprovechar [vulnerabilidad o condición] y afectar [activo o proceso], la organización podría experimentar [impacto empresarial].

Ejemplo: Debido a que un atacante puede usar credenciales administrativas robadas contra un servicio remoto expuesto a Internet que no exige MFA resistente al phishing, la organización podría sufrir acceso no autorizado, ransomware, interrupción operativa y divulgación de datos.

2. Funciones, gobierno e independencia

Función	Responsabilidades
Patrocinador ejecutivo	Aprueba el alcance, elimina barreras y acepta o escala riesgos importantes.
Propietario del riesgo	Es responsable del objetivo de negocio y decide el tratamiento dentro de su autoridad.
Líder de la evaluación	Planifica, aplica el método de forma

	consistente y conserva la evidencia.
Propietario del sistema o servicio	Explica arquitectura, dependencias, usuarios, cambios y controles.
Propietario del control	Opera la salvaguarda y proporciona evidencia.
Especialistas	Aportan análisis técnico, legal, de privacidad, seguridad humana y cumplimiento.
Auditor o revisor independiente	Cuestiona supuestos y evalúa la calidad.
Tercero	Proporciona información precisa sobre servicios, controles, incidentes y dependencias.

- Documente conflictos de interés.
- No permita que el propietario del control sea el único evaluador de su eficacia.
- Registre desacuerdos y autoridad de decisión.
- Proteja entrevistas, arquitectura, vulnerabilidades y registros según su clasificación.

3. Definición del alcance y contexto

Un alcance claro evita que la evaluación sea superficial o interminable. Comience con el objetivo de negocio y después identifique la tecnología y las dependencias que lo soportan.

Elemento	Preguntas
Propósito	¿Qué objetivo de misión, cliente, legal, seguridad o ingresos soporta?
Límite	¿Qué aplicaciones, identidades, redes, ubicaciones, nubes, API y endpoints se incluyen?
Datos	¿Qué datos se recopilan, procesan, transmiten, almacenan, registran o eliminan?
Personas	¿Quién administra, usa, soporta, aprueba o se ve afectado?
Proveedores	¿Qué proveedores, procesadores, componentes y servicios públicos son dependencias?
Horizonte	¿Se evalúa el estado actual, un cambio, una adquisición o una estrategia?
Criterios	¿Qué escalas de probabilidad, impacto, nivel y aceptación se usarán?
Limitaciones	¿Qué restricciones de evidencia, tiempo, acceso, presupuesto o conocimiento existen?

Declaración mínima de alcance

Esta evaluación cubre [servicio y proceso], incluidos [sistemas, datos, identidades, entornos y proveedores], durante [periodo]. Evalúa [tipos de riesgo] mediante [método y escalas]. Excluye [elementos], que serán atendidos por [propietario/fecha o evaluación separada].

4. Identificación de activos, servicios y datos

- Comience por los servicios críticos de negocio, no solo por una lista de dispositivos.
- Mapee sistemas, aplicaciones, identidades, datos, redes, instalaciones y proveedores.
- Identifique activos esenciales y puntos únicos de falla.
- Registre clasificación, residencia, retención y requisitos de respaldo.
- Documente dependencias anteriores y posteriores.
- Valide el inventario con evidencia técnica, CMDB, directorios, diagramas, nube y contratos.

Campo	Ejemplo
Servicio	Pagos en línea
Propietario	Director de Comercio Digital
Criticidad	Alta
Datos	Pagos y contacto del cliente
RTO/RPO	4 horas / 30 minutos
Dependencias	Identidad, nube, procesador de pagos, DNS
Exposición	Internet
Evidencia	Diagrama, CMDB, flujo de datos, contrato

5. Identificación de amenazas y eventos

No use únicamente una lista genérica. Conecte actores y condiciones creíbles con eventos específicos que puedan afectar el objetivo evaluado.

Fuente	Eventos de ejemplo
Delincuencia externa	Phishing, ransomware, relleno de credenciales, extorsión y fraude.
Actor avanzado	Espionaje, compromiso de cadena de suministro y operaciones destructivas.
Persona interna	Robo, sabotaje, divulgación o evasión deliberada.
Error humano	Mala configuración, borrado, destinatario equivocado o intercambio inseguro.
Proveedor	Caída, actualización comprometida, acceso débil o demora en notificación.
Falla tecnológica	Corrupción, certificado vencido, defecto o falta de capacidad.
Ambiente físico	Falla eléctrica, incendio, inundación, robo o refrigeración.
Falla de gobierno	Propiedad confusa, uso de IA no aprobado, retención ausente o excepciones sin control.

- Use incidentes, casi incidentes, hallazgos, fraude, soporte y auditoría.
- Use inteligencia de amenazas confiable y alertas sectoriales.
- Diferencie posibilidad de credibilidad.

- No descarte una amenaza solo porque nunca ocurrió antes.

6. Identificación de vulnerabilidades y brechas

Una vulnerabilidad puede ser técnica, procesal, contractual, organizacional, física o humana. No toda ausencia de control es automáticamente una vulnerabilidad; explique cómo la condición facilita o agrava el evento.

Fuente de evidencia	Qué puede revelar
Configuración	Exposición pública, autenticación débil, permisos excesivos y valores inseguros.
Escaneo	Fallos conocidos y parches faltantes.
Prueba de penetración	Rutas explotables dentro de un alcance autorizado.
Entrevista	Propiedad confusa, procesos manuales y operación inconsistente.
Muestreo	Aprobaciones fallidas, revisiones incompletas y registros ausentes.
Incidentes	Controles que fallaron en condiciones reales.
Contratos	Limitaciones, exclusiones y compromisos débiles.
Arquitectura	Límites de confianza, segmentación, concentración y puntos únicos de falla.

Calidad de evidencia

- Prefiera evidencia actual, directa y reproducible.
- Registre fecha, fuente, propietario y limitaciones.
- Una política no demuestra operación.
- Una muestra exitosa no demuestra consistencia.
- Cuando falte evidencia, registre incertidumbre.

7. Análisis de probabilidad

La probabilidad es un juicio informado sobre la posibilidad de que el evento ocurra y produzca daño durante el horizonte definido. Use criterios y evidencia, no intuición aislada.

Nivel	Criterio de ejemplo
1 - Raro	No se espera; existen barreras fuertes y no hay historia o targeting creíble.
2 - Improbable	Es posible, pero requiere condiciones inusuales o varias fallas.
3 - Posible	Es creíble y podría ocurrir; existen eventos similares.
4 - Probable	Se espera en muchas circunstancias; hay exposición, intentos o barreras débiles.

5 - Casi seguro	Se espera repetidamente o ya está ocurriendo.
-----------------	---

- Considere capacidad, intención, targeting, frecuencia, exposición, facilidad de explotación y confiabilidad de controles.
- Separe probabilidad de impacto.
- Indique el horizonte, por ejemplo 12 meses.
- Documente incertidumbre y use escenarios cuando la evidencia sea débil.

8. Análisis de impacto

El impacto debe describir consecuencias para los objetivos y las personas, no solamente severidad técnica.

Área	Preguntas
Seguridad humana	¿Puede causar daño físico, negar servicios esenciales, discriminar o producir angustia grave?
Operaciones	¿Cuánto tiempo puede estar degradado el servicio y qué alternativa existe?
Confidencialidad y privacidad	¿Qué datos, a quién y a qué escala pueden exponerse?
Integridad	¿Pueden alterarse registros, decisiones, modelos o finanzas?
Finanzas	¿Qué costos de respuesta, fraude, ingresos, multas o contratos existirían?
Legal y regulatorio	¿Qué notificación, investigación, litigio o licencia se afecta?
Confianza	¿Perderían confianza clientes, empleados, socios o público?
Estrategia	¿Impediría objetivos, adquisiciones o transformación?

Nivel	Criterio de ejemplo
1 - Insignificante	Interrupción mínima y sin consecuencia material.
2 - Menor	Impacto local, recuperación rutinaria y costo pequeño.
3 - Moderado	Interrupción material, asunto reportable o impacto significativo.
4 - Mayor	Interrupción grave, exposición importante, acción regulatoria o gran pérdida.
5 - Catastrófico	Riesgo para vida o servicios esenciales, falla empresarial o daño existencial.

9. Cálculo y comunicación del riesgo

Una matriz ayuda a la consistencia, pero la multiplicación no crea precisión científica. La narrativa, evidencia, incertidumbre y contexto importan más que la aritmética.

Probabilidad x Impacto	Nivel sugerido
1-4	Bajo
5-9	Moderado
10-16	Alto
17-25	Crítico

Impacto → / Probabilidad ↓	1	2	3	4	5
5 - Casi seguro	5 M	10 A	15 A	20 C	25 C
4 - Probable	4 B	8 M	12 A	16 A	20 C
3 - Posible	3 B	6 M	9 M	12 A	15 A
2 - Improbable	2 B	4 B	6 M	8 M	10 A
1 - Raro	1 B	2 B	3 B	4 B	5 M

- Defina escalas antes de comenzar.
- Permita juicio profesional documentado cuando la matriz no refleje la consecuencia real.
- No promedie riesgos no relacionados.
- Explique la evidencia detrás de cada nivel.

10. Evaluación de controles y riesgo residual

Evalúe diseño y eficacia operativa. Un control bien redactado que no se ejecuta no reduce el riesgo.

Dimensión	Preguntas
Diseño	¿El control puede reducir el escenario?
Implementación	¿Está desplegado en todo el alcance?
Operación	¿Se ejecuta con frecuencia y consistencia?
Cobertura	¿Protege identidades, sistemas, ubicaciones y proveedores relevantes?
Confiabilidad	¿Está automatizado, monitoreado, probado y protegido contra evasión?
Evidencia	¿Puede demostrarse su operación?
Dependencias	¿Depende de otro control que puede fallar?

Eficacia	Descripción
Eficaz	Diseñado, implementado, operando y evidenciado.
Parcialmente eficaz	Reduce el riesgo, pero tiene brechas.

Ineficaz	No reduce de forma confiable.
No implementado	Está previsto o requerido, pero ausente.
No evaluado	No existe evidencia suficiente; debe registrarse la incertidumbre.

Recalifique probabilidad e impacto después de considerar controles eficaces. Compare el riesgo residual con apetito, tolerancia y autoridad delegada.

11. Planes de tratamiento

Opción	Uso
Mitigar	Agregar o mejorar controles.
Evitar	Detener la actividad, eliminar exposición o cambiar el diseño.
Transferir o compartir	Usar seguros, contratos o terceros, reconociendo que puede permanecer responsabilidad.
Aceptar	Retener formalmente dentro de autoridad y tolerancia, con justificación y fecha.

Acciones SMART

- Específica: identifique el cambio exacto.
- Medible: defina evidencia y criterio de éxito.
- Asignada: nombre un propietario responsable.
- Realista: confirme recursos y dependencias.
- Con fecha: establezca hitos y fecha final.

Acción débil	Acción mejorada
Mejorar acceso	Antes del 30 de septiembre, migrar todo acceso remoto privilegiado a MFA resistente al phishing, eliminar cuentas compartidas y entregar evidencia de configuración e inicio de sesión.
Parchar servidores	En 30 días, corregir vulnerabilidades críticas expuestas; reportar excepciones semanalmente con controles compensatorios.
Capacitar usuarios	Capacitar al 95% con contenido por función, medir reporte de phishing y repetir para grupos de alto riesgo.

12. Registro de riesgos

Campo	Propósito
-------	-----------

ID y título	Referencia única y nombre conciso.
Objetivo y activo	Qué está en riesgo y por qué importa.
Declaración	Amenaza, condición, activo y consecuencia.
Alcance y supuestos	Límite, horizonte, exclusiones e incertidumbre.
Controles	Salvaguardas relevantes.
Evidencia	Documentos, registros, pruebas, entrevistas y fechas.
Riesgo inherente	Probabilidad e impacto antes de controles.
Eficacia	Conclusión de diseño y operación.
Riesgo residual	Probabilidad e impacto posteriores.
Propietario	Responsable de la decisión.
Tratamiento	Acciones, hitos, evidencia y fecha.
Autoridad de aceptación	Persona autorizada para aceptar.
Estado y revisión	Seguimiento y detonador de reevaluación.

Ejemplo completo

Campo	Ejemplo
Título	Compromiso de acceso remoto privilegiado
Declaración	Un atacante puede usar credenciales robadas contra acceso remoto sin MFA resistente al phishing, causando acceso no autorizado, ransomware, interrupción y divulgación.
Inherente	Probabilidad 4; Impacto 5; Crítico 20
Controles	MFA por contraseña para la mayoría, registros VPN y protección de endpoints.
Eficacia	Parcial; permanecen cuentas heredadas y administración compartida.
Residual	Probabilidad 3; Impacto 5; Alto 15
Tratamiento	MFA resistente al phishing, eliminar cuentas compartidas, restringir origen, estaciones privilegiadas y prueba de recuperación.
Propietario y fecha	Director de Infraestructura; 30 de septiembre de 2026
Detonador	Cambio material, incidente relacionado o fecha de vencimiento.

13. Informes para líderes

- Comience con objetivos y decisiones requeridas.
- Muestre riesgos principales, tendencias, acciones vencidas, riesgos aceptados y concentración.
- Separe hechos, supuestos y juicio profesional.
- Explique incertidumbre y limitaciones.
- No abrume con conteos de vulnerabilidades.
- Adapte detalle para responsables técnicos.

- Conserve decisiones y aprobaciones.

Resumen ejecutivo de una página

- Alcance y fecha
- Conclusión general
- Tres a cinco escenarios principales
- Impacto empresarial
- Fortalezas existentes
- Acciones e inversión
- Riesgos que requieren aceptación o escalamiento
- Supuestos y limitaciones
- Próxima revisión

14. Monitoreo y reevaluación

El riesgo cambia. Reevalue después de cambios significativos y según la criticidad.

- Nuevo sistema, nube, IA, proveedor, fusión o adquisición
- Cambio material de arquitectura o datos
- Vulnerabilidad o campaña importante
- Incidente o casi incidente
- Falla de control o tratamiento vencido
- Cambio regulatorio o contractual
- Cambio de criticidad
- Fecha periódica

Indicador	Ejemplo
KRI	Porcentaje de cuentas privilegiadas sin MFA resistente al phishing.
Indicador de control	Porcentaje de sistemas críticos enviando registros al SIEM.
Indicador de tratamiento	Riesgos altos vencidos por propietario.
Indicador de exposición	Vulnerabilidades críticas expuestas con más de 15 días.
Indicador de resiliencia	Servicios críticos con objetivos de recuperación probados.

15. Errores comunes y control de calidad

Error	Mejor práctica
Comenzar con una lista genérica	Comience con servicio, objetivo y flujo de datos.
Calificar todo como alto	Use criterios y escenarios específicos.
Confundir cumplimiento con seguridad	Evalúe amenazas, controles y consecuencias.

Contar políticas como controles operativos	Pruebe implementación y evidencia.
Ignorar proveedores y concentración	Mappee dependencias y fallas comunes.
Ocultar incertidumbre	Registre evidencia faltante y confianza.
Aceptar sin autoridad	Use límites de aceptación delegados.
Tratamiento vago	Defina propietario, acción, evidencia y fecha.
No cerrar el ciclo	Vuelva a probar y actualice el residual.

Lista de calidad

- ☐ Alcance explícito y aprobado
- ☐ Declaraciones que conectan amenaza, condición, activo y consecuencia
- ☐ Criterios definidos
- ☐ Evidencia actual y trazable
- ☐ Diferencia clara entre inherente y residual
- ☐ Eficacia respaldada
- ☐ Acciones específicas y asignadas
- ☐ Aceptación por autoridad correcta
- ☐ Limitaciones visibles
- ☐ Detonadores y fechas registrados

16. Proyecto de portafolio y plan de 30/60/90 días

Proyecto seguro

- Use una empresa ficticia o laboratorio autorizado.
- Cree alcance y diagrama sencillo.
- Inventarie de cinco a diez activos.
- Escriba cinco escenarios creíbles.
- Defina escalas.
- Evalúe controles y residual.
- Cree registro y resumen ejecutivo.
- Publique únicamente información ficticia o saneada.

Primeros 30 días

- Estudiar vocabulario, NIST CSF 2.0 y NIST SP 800-30.
- Practicar declaraciones de riesgo.
- Crear criterios de probabilidad e impacto.
- Crear inventario y registro de ejemplo.

Días 31 a 60

- Evaluar un servicio ficticio o autorizado.
- Practicar entrevistas y evidencia.
- Redactar tratamientos y resumen ejecutivo.
- Solicitar revisión crítica de un mentor.

Días 61 a 90

- Mapear riesgos a controles y objetivos.
- Crear métricas y detonadores.
- Publicar portafolio saneado en GitHub.
- Practicar explicación para un responsable técnico y un ejecutivo.

17. Plantillas y ejemplos

Preguntas de entrevista

- ¿Qué objetivo soporta el servicio?
- ¿Qué ocurre si no está disponible una hora, un día o una semana?
- ¿Qué datos sensibles procesa?
- ¿Quién tiene acceso privilegiado y cómo se revisa?
- ¿Qué proveedores son esenciales?
- ¿Qué incidentes o casi incidentes ocurrieron?
- ¿Qué controles son manuales o difíciles de evidenciar?
- ¿Qué cambios próximos alterarán el riesgo?
- ¿Qué decisiones necesitan aprobación ejecutiva?

ID	Acción	Propietario	Hito	Fecha	Evidencia	Estado
R-001	Implementar MFA resistente al phishing	Gerente IAM	Piloto terminado	2026-09-30	Configuración y registros	Abierto
R-002	Probar recuperación fuera de línea	Gerente de Infraestructura	Ejercicio de restauración	2026-10-15	Informe del ejercicio	Planificado

18. Glosario y referencias oficiales

Término	Definición
Riesgo	Efecto de la incertidumbre sobre los objetivos; suele expresarse con probabilidad e impacto.
Escenario	Descripción estructurada de cómo un evento produce consecuencias.

Riesgo inherente	Riesgo antes de controles actuales.
Riesgo residual	Riesgo después de controles.
Diseño del control	Capacidad del control para reducir el riesgo.
Eficacia operativa	Consistencia real del control.
Propietario del riesgo	Persona responsable de administrarlo y decidir.
Aceptación	Decisión autorizada de retener el residual.
KRI	Indicador clave para monitorear exposición.
Detonador	Evento o fecha que exige reevaluación.

[NIST SP 800-30 Rev. 1 - Guide for Conducting Risk Assessments](#)

[NIST Cybersecurity Framework 2.0](#)

[NIST Risk Management Framework](#)

[CISA Risk Assessments](#)

Copyright © 2026 Alberto (Al) Leiva. Licencia CC BY-NC-SA 4.0.